Universidad de Extremadura

Escuela Politécnica

Ingeniería Informática en Ingeniería del Software

Trabajo Fin de Grado

Desarrollo de una herramienta para la automatización de tareas de reconocimiento en auditorías de seguridad

David Gordillo Burrero

Convocatoria, 2025

Universidad de Extremadura

Escuela Politécnica

Ingeniería Informática en Ingeniería del Software

Trabajo Fin de Grado

Desarrollo de una herramienta para la automatización de tareas de reconocimiento en auditorías de seguridad

Autor: David Gordillo Burrero

Tutor: Tutor

Resumen

En el presente trabajo se ha desarrollado una herramienta orientada a la automatización de tareas fundamentales en auditorías de seguridad, con un enfoque específico en la fase de reconocimiento. Esta etapa, crítica en cualquier proceso de pentesting, abarca actividades como la recolección de información pasiva y activa, el escaneo de puertos y servicios, la enumeración de subdominios y tecnologías, así como la identificación preliminar de posibles vulnerabilidades.

La solución propuesta integra múltiples utilidades y técnicas ampliamente utilizadas en entornos profesionales de ciberseguridad (como Nmap, Feroxbuster, WhatWeb o WPScan), y se construye sobre una arquitectura modular y escalable que permite incorporar nuevas funcionalidades de forma sencilla en el futuro. A través de una interfaz web intuitiva, el usuario puede gestionar proyectos, ejecutar escaneos personalizados y consultar resultados de manera clara y estructurada.

Esta herramienta permite optimizar el flujo de trabajo durante las fases iniciales de una auditoría, automatizando tareas repetitivas, centralizando la información obtenida y reduciendo significativamente los tiempos de ejecución. Por otra parte, incorpora un sistema de inteligencia artificial basado en modelos generativos, que facilita la interacción con el contexto del escaneo para obtener recomendaciones específicas o definir próximos pasos según las debilidades detectadas. Además, genera automáticamente informes técnicos versionados, lo que simplifica la documentación del proceso y mejora su trazabilidad sin necesidad de intervención manual.

Palabras clave: Seguridad, Hacking Ético, Auditoría, Automatización, Herramienta.

Abstract

This project presents the development of a tool aimed at automating fundamental tasks in security audits, with a specific focus on the reconnaissance phase. This stage, which is critical in any penetration testing process, includes activities such as passive and active information gathering, port and service scanning, subdomain and technology enumeration, and the preliminary identification of potential vulnerabilities.

The proposed solution integrates several tools and techniques widely used in professional cybersecurity environments (such as Nmap, Feroxbuster, WhatWeb, or WPScan), and is built on a modular and scalable architecture that facilitates the future incorporation of new functionalities. Through an intuitive web interface, users can efficiently manage projects, execute customized scans, and review results in a clear and structured way.

The tool helps optimize workflow during the initial stages of a security audit by automating repetitive tasks, centralizing collected data, and significantly reducing execution time. Moreover, it includes an artificial intelligence system based on generative models, which allows users to interact with the scan context to receive specific recommendations or define next steps based on detected weaknesses. Additionally, it automatically generates versioned technical reports, streamlining the documentation process and improving traceability without requiring manual intervention.

Keywords: Security, Ethical Hacking, Auditing, Automation, Tool.

Índice general

1. Introducción **1**

1.1. Estructura del documento 3

2. Objetivos **5**

2.1. Subobjetivos específicos 6

3. Estado del Arte **8**

3.1. Evolución de las auditorías de seguridad 9

3.2. Herramientas de reconocimiento automatizado 10

3.2.1. ProjectDiscovery Cloud 11

3.2.2. Intruder.io 12

3.2.3. Detectify 14

3.3. Comparativa de las soluciones analizadas 15

4. Metodología **17**

4.1. Escaneo de puertos y servicios 19

4.2. Enumeración de dominio 19

4.2.1. Reconocimiento DNS 19

4.2.2. OSINT de direcciones de correo electrónico 20

4.2.3. Enumeración de subdominios 20

4.3. Reconocimiento web 20

4.3.1. Escaneo de vulnerabilidades web 21

4.3.2. Detección de CMS 21

4.3.3. Captura de pantalla del sitio web 21
4.3.4. Enumeración de directorios y archivos 21
4.3.5. Reconocimiento de WordPress 21
4.3.6. Reconocimiento de Joomla 22
4.4. Enumeración del servicio FTP 22
4.5. Reconocimiento del servicio SSH 22
4.6. Generación de reportes 23
4.7. Funcionalidades adicionales 23

5. Implementación y desarrollo **25**

6. Resultados **26**

7. Conclusiones y trabajos futuros **27**

Anexos **28**

A. Ejemplo de anexo **29**
A.1. Sección de anexo 29

Bibliografía **30**

Índice de tablas

3.1. Comparativa entre la herramienta desarrollada y soluciones similares. . . . 16

Índice de figuras

Capítulo 1

Introducción

Contenidos

1.1. Estructura del documento 3

En el ámbito de la ciberseguridad, el **reconocimiento** constituye una de las fases más importantes dentro de una **auditoría**. Esta fase inicial tiene como objetivo recopilar la máxima cantidad de información posible sobre el objetivo a analizar [1]. A partir de estos datos, el auditor puede identificar servicios expuestos, tecnologías empleadas y potenciales vectores de ataque, sentando así las bases para etapas más avanzadas como la explotación o escalación de privilegios.

A pesar de su importancia, las tareas asociadas al reconocimiento suelen ser **repetitivas**, tediosas y propensas a errores si se realizan manualmente. Además, muchas de las herramientas empleadas requieren conocimientos técnicos, uso de línea de comandos y un esfuerzo considerable para gestionar los resultados obtenidos. Este escenario genera una necesidad clara de soluciones que permitan automatizar este proceso, reducir los tiempos de ejecución y facilitar la gestión de la información recopilada.

El presente Trabajo de Fin de Grado surge como respuesta a esta problemática. Se ha desarrollado una herramienta que **automatiza** las tareas fundamentales de reconocimiento en una auditoría de seguridad, integrando distintas utilidades en un único entorno con **interfaz gráfica**. Esta solución permite realizar desde escaneos de puertos y servicios hasta la enumeración de subdominios, identificación de vulnerabilidades web, detección de CMS y análisis de servicios como FTP o SSH. Además, la herramienta permite interactuar con un sistema de **inteligencia artificial** basado en modelos generativos, que facilita la interpretación de resultados y la propuesta de acciones posteriores.

Entre las funcionalidades añadidas destacan también la generación automática y versionada de **informes**, la configuración de escaneos exhaustivos, la personalización del entorno mediante proxies y un sistema de proyectos que organiza los análisis por objetivo.

La herramienta está diseñada con una arquitectura **modular y escalable**, lo que permite incorporar en un futuro nuevas funcionalidades de forma sencilla. Esto la convierte en una solución con **capacidad para seguir evolucionando** y ampliándose mediante la integración de nuevos módulos que permitan cubrir un mayor número de servicios y

casos de uso.

Durante el desarrollo se han evaluado múltiples alternativas tecnológicas, priorizando aquellas que ofrecieran un equilibrio entre rendimiento, actualización activa, facilidad de integración y compatibilidad. Herramientas como Nmap, Subfinder, Nuclei, WPScan o Feroxbuster han sido seleccionadas tras un análisis comparativo, mientras que otras como Nikto, Gobuster o Paramiko fueron descartadas por distintos motivos técnicos.

El resultado es una herramienta funcional, útil y extensible, capaz de **reducir significativamente el tiempo** y la carga de trabajo durante la fase de reconocimiento, agilizando así el proceso de auditoría y mejorando la calidad del análisis desde las primeras etapas.

1.1. Estructura del documento

Este documento se encuentra estructurado en siete capítulos, además de las correspondientes referencias bibliográficas. A continuación, se describe brevemente el contenido de cada uno de ellos:

- El **Capítulo 2** recoge los objetivos que se pretenden alcanzar con el desarrollo de la herramienta propuesta.
- El **Capítulo 3** presenta el estado del arte, en el que se analizan las principales herramientas existentes en el ámbito del reconocimiento automatizado y se identifican sus principales limitaciones.
- El **Capítulo 4** describe la metodología seguida para el desarrollo de la herramienta, justificando la elección de cada tecnología empleada y explicando el flujo de trabajo que se implementa durante el proceso de reconocimiento.
- El **Capítulo 5** detalla el proceso de implementación de la herramienta, desde el diseño de su arquitectura hasta la integración de sus distintos módulos.

- El **Capítulo 6** recoge los resultados obtenidos a partir de las pruebas realizadas sobre distintos escenarios, evaluando la eficacia de la herramienta y el cumplimiento de los objetivos definidos.

- El **Capítulo 7** expone las conclusiones extraídas del trabajo, así como posibles líneas futuras de mejora y ampliación del sistema desarrollado.

- Finalmente, se incluyen las **referencias bibliográficas** consultadas a lo largo del proyecto.

Capítulo 2

Objetivos

Contenidos

2.1. Subobjetivos específicos **6**

El principal objetivo de este Trabajo de Fin de Grado consiste en desarrollar una herramienta que **automatice** las tareas asociadas a la fase de reconocimiento de una auditoría, facilitando y agilizando la **recopilación de información** sobre un objetivo. Con ello se pretende **reducir significativamente el tiempo**, la carga de trabajo y los recursos humanos necesarios para realizar dichas tareas de forma manual, al mismo tiempo que se proporciona una **interfaz gráfica** intuitiva, fácil de usar y con distintas opciones de configuración que la hagan accesible también a perfiles sin conocimientos técnicos avanzados.

2.1. Subobjetivos específicos

Como consecuencia de este objetivo principal, se identifican los siguientes **subobjetivos específicos**:

- Estudiar la **metodología** seguida en la fase de reconocimiento de una auditoría de seguridad.
- Analizar las distintas **alternativas tecnológicas** disponibles para cada tarea de reconocimiento, con el fin de seleccionar las opciones más adecuadas en términos de rendimiento, flexibilidad e integración.
- Desarrollar **módulos individuales** responsables de cada una de las tareas clave que componen la fase de reconocimiento.
- **Orquestar** las herramientas seleccionadas bajo una única solución que gestione y controle el flujo de ejecución entre los diferentes módulos.
- Diseñar una arquitectura **modular y escalable** que permita futuras ampliaciones y facilite el mantenimiento del sistema.
- Implementar una interfaz gráfica amigable que simplifique el uso de la herramienta, incluso para usuarios con **conocimientos técnicos limitados**.

- Incorporar un sistema de gestión de objetivos basado en **proyectos**, con el objetivo de mejorar la organización y el seguimiento de los análisis realizados.
- Integrar un sistema de **inteligencia artificial** que proporcione asistencia contextual al usuario y sugerencias sobre acciones posteriores a los resultados obtenidos.
- **Generar informes** técnicos de forma automática a partir de los resultados del reconocimiento, presentando la información de manera clara y visual.
- Permitir la ejecución de la herramienta mediante **consola**, ampliando su adaptabilidad a distintos perfiles de usuario.
- Ofrecer distintas **opciones de configuración** para que la herramienta pueda ajustarse a distintos escenarios de análisis y niveles de profundidad.

Capítulo 3

Estado del Arte

Contenidos

3.1. Evolución de las auditorías de seguridad 9

3.2. Herramientas de reconocimiento automatizado 10

3.2.1. ProjectDiscovery Cloud 11

3.2.2. Intruder.io 12

3.2.3. Detectify 14

3.3. Comparativa de las soluciones analizadas 15

3.1. Evolución de las auditorías de seguridad

Las **auditorías de seguridad** informática surgieron como una respuesta directa al crecimiento exponencial de las redes informáticas y a la necesidad de proteger la información en entornos corporativos y gubernamentales. A medida que las tecnologías digitales comenzaron a formar parte de infraestructuras críticas y operaciones empresariales a gran escala, también aumentaron los incidentes relacionados con accesos no autorizados, robo de información, interrupciones de servicio y ataques maliciosos.

El concepto de auditoría de seguridad se consolidó a finales de los años 70 y principios de los 80, coincidiendo con la adopción masiva de **sistemas informáticos interconectados**. Durante este periodo, se desarrollaron algunos de los primeros estudios sistemáticos sobre cómo evaluar la seguridad de sistemas informáticos ante accesos no autorizados o comportamientos anómalos. Un ejemplo temprano es el informe ***Computer Security Technology Planning Study*** elaborado por James P. Anderson en 1972 [2, 3], considerado uno de los documentos fundacionales en la definición de objetivos y estrategias para el análisis técnico de la seguridad.

Durante los años 90, con la expansión global de Internet, surgieron las primeras metodologías estructuradas de auditoría como respuesta a nuevas amenazas, especialmente enfocadas en proteger servidores web, sistemas de correo y bases de datos. Herramientas como `SATAN` (Security Administrator Tool for Analyzing Networks), lanzada en 1995, marcaron un hito como una de las primeras aplicaciones orientadas a la detección de vulnerabilidades de red de forma semiautomática [4].

En paralelo, comenzaron a popularizarse los conceptos de "**penetration testing**" (pruebas de penetración) y "**ethical hacking**", que planteaban escenarios controlados de ataque con el fin de identificar debilidades antes de que pudieran ser explotadas por actores maliciosos. Con el tiempo, este enfoque evolucionó en metodologías más completas, como **OSSTMM** (Open Source Security Testing Methodology Manual) [5] o **OWASP Testing Guide** [6], que establecieron marcos de referencia para evaluar sistemas desde

una perspectiva técnica y organizada.

Actualmente, las auditorías de seguridad constituyen una práctica esencial dentro de la ciberseguridad defensiva y ofensiva. Su objetivo no se limita únicamente a identificar vulnerabilidades, sino también a priorizarlas, documentarlas y proponer soluciones antes de que puedan ser explotadas en un entorno real. La creciente complejidad de los entornos IT y la aparición de nuevos vectores de ataque han motivado la evolución constante de estas auditorías hacia **modelos más automatizados**, escalables y adaptables a distintos perfiles de organización.

3.2. Herramientas de reconocimiento automatizado

Con la creciente demanda de eficiencia en los procesos de auditoría de seguridad, especialmente en sus fases iniciales, han surgido en los últimos años múltiples plataformas orientadas a la **automatización del reconocimiento** y la **detección de vulnerabilidades**. Estas herramientas buscan reducir la carga operativa del analista, minimizar errores humanos y mejorar la cobertura frente a configuraciones y tecnologías cada vez más diversas.

Una de las propuestas más destacadas en este ámbito es **ProjectDiscovery Cloud** [7], una plataforma construida sobre herramientas open source ampliamente utilizadas en la comunidad de ciberseguridad, como `Nuclei`, `Httpx`, `Subfinder` o `Dnsx`. Su enfoque se basa en ofrecer un **entorno colaborativo**, escalable y continuamente actualizado para la detección de vulnerabilidades en activos expuestos a Internet. Aunque su núcleo es técnico, la plataforma proporciona una interfaz web amigable para la gestión de proyectos, permitiendo a los equipos de seguridad integrar fácilmente estos escaneos en flujos de trabajo automatizados.

Otra alternativa relevante es **Intruder.io** [8], un servicio orientado a empresas que buscan externalizar parte de su vigilancia de ciberseguridad. Intruder.io se centra en

la gestión de vulnerabilidades y la supervisión de la superficie de ataque, integrándose con entornos cloud como AWS o Azure. Su propuesta incluye escaneos automáticos, priorización de riesgos y reportes con recomendaciones técnicas, sin requerir una intervención manual intensiva, aunque con una menor flexibilidad técnica en comparación con herramientas de línea de comandos.

Por su parte, **Detectify** [9] ofrece un enfoque complementario basado en la **inteligencia colectiva**, donde una comunidad de hackers éticos colabora aportando módulos de detección de vulnerabilidades, incluyendo incluso algunos **0-days** [10]. Esta plataforma permite escaneos web completos, incluyendo aplicaciones protegidas por autenticación, y destaca por su **integración con herramientas de desarrollo** y gestión como GitHub, Jira o Slack. Además, incorpora técnicas de fingerprinting avanzadas para adaptar sus pruebas al stack tecnológico específico de cada objetivo.

3.2.1. ProjectDiscovery Cloud

ProjectDiscovery Cloud es una plataforma de seguridad ofensiva que se construye sobre herramientas de código abierto ampliamente adoptadas por la comunidad de pentesting, como `Nuclei`, `Httpx`, `Subfinder`, `Naabu` o `Dnsx`. Su objetivo principal es facilitar la automatización del reconocimiento y la identificación de vulnerabilidades en activos expuestos, ofreciendo una experiencia escalable, colaborativa y fácil de integrar en flujos de trabajo modernos.

Entre sus principales características destacan:

- **Escaneo de puertos y servicios**: utiliza `Naabu` para detectar puertos abiertos en los objetivos definidos, permitiendo descubrir servicios accesibles desde Internet.
- **Enumeración de subdominios**: se apoya en `Subfinder` para identificar subdominios del dominio objetivo, lo cual permite ampliar la superficie de ataque.
- **Escaneo de vulnerabilidades web**: emplea `Nuclei` como motor principal para

ejecutar pruebas basadas en plantillas YAML contra los activos detectados. Estas plantillas permiten buscar fallos de seguridad en servicios HTTP, encabezados, tecnologías, versiones o patrones de exposición comunes.

- **Detección de tecnologías**: con herramientas como `Httpx`, la plataforma identifica frameworks, CMS o servidores web en uso.
- **Gestión de proyectos**: permite organizar los objetivos dentro de espacios de trabajo, visualizar resultados agrupados y priorizar vulnerabilidades según su criticidad.
- **Interfaz web y CLI**: proporciona tanto una interfaz gráfica intuitiva como una línea de comandos para ejecutar las herramientas por separado o integrarlas en scripts.

Sin embargo, la plataforma tiene ciertas limitaciones. Por ejemplo, no incluye reconocimiento detallado de servicios específicos como FTP o SSH, ni ofrece funciones de OSINT orientadas a la detección de correos filtrados o información expuesta de usuarios. Tampoco integra asistentes inteligentes para analizar los resultados, ni proporciona informes de forma nativa.

En cuanto a la disponibilidad, ProjectDiscovery Cloud ofrece una modalidad gratuita con funcionalidades limitadas, ideal para usuarios técnicos que ya están familiarizados con sus herramientas open source. Los planes comerciales amplían capacidades como la colaboración multiusuario o el acceso a plantillas explusivas.

3.2.2. Intruder.io

Intruder.io es una plataforma de escaneo de vulnerabilidades enfocada en entornos empresariales, cuyo objetivo principal es simplificar la supervisión de la superficie de ataque y automatizar la detección de debilidades técnicas. Su propuesta se centra

en ofrecer una experiencia gestionada, accesible a equipos de TI y seguridad que no necesariamente cuentan con perfiles técnicos especializados.

Las características principales de Intruder.io incluyen:

- **Escaneo de puertos y servicios**: permite identificar puertos abiertos y servicios disponibles en los activos definidos, tanto en entornos externos como internos. Esta capacidad es parte de su sistema de supervisión continua.
- **Enumeración de subdominios**: incluye detección automática de subdominios asociados a dominios registrados, para ampliar la visibilidad sobre activos inadvertidos.
- **Escaneo de vulnerabilidades web**: utiliza una base de pruebas automatizadas para detectar vulnerabilidades comunes en aplicaciones web, como inyecciones, XSS o configuraciones inseguras.
- **Gestión de activos y proyectos**: organiza los resultados por organización y objetivos, permitiendo la priorización basada en el riesgo, e integración con herramientas como AWS o Azure para escanear nuevos servicios desplegados automáticamente.
- **Interfaz web**: proporciona una interfaz gráfica sencilla, centrada en accesibilidad y claridad de resultados.

A pesar de las características previamente mencionadas, Intruder.io presenta varias limitaciones comparado con la solución propuesta en este trabajo. No permite ejecución mediante línea de comandos, lo cual restringe su integración en flujos automatizados personalizados. Tampoco realiza reconocimiento específico sobre servicios como FTP o SSH, ni incluye análisis de correos expuestos o técnicas de OSINT. Además, no ofrece análisis mediante inteligencia artificial para la interpretación de los resultados obtenidos.

Su modelo de uso se basa principalmente en suscripción comercial. No dispone de una versión gratuita para auditorías técnicas avanzadas, lo que puede suponer una barrera de entrada para usuarios individuales.

3.2.3. Detectify

Detectify es una plataforma de escaneo de seguridad web orientada a organizaciones que necesitan identificar y corregir vulnerabilidades en aplicaciones expuestas a Internet. Su enfoque combina el uso de pruebas automatizadas con inteligencia de amenazas aportada por una comunidad de más de 400 hackers éticos, quienes contribuyen con módulos de detección actualizados, incluyendo vulnerabilidades recientes e incluso 0-days.

Entre sus principales funcionalidades destacan:

- **Escaneo de puertos y servicios**: realiza detección básica de servicios expuestos, aunque centrado principalmente en protocolos web.
- **Enumeración de subdominios**: detecta subdominios relacionados con el dominio objetivo, y los incluye como parte del análisis continuo de la superficie de ataque.
- **Reconocimiento DNS**: ofrece visibilidad sobre registros DNS, lo que permite detectar configuraciones erróneas y posibles riesgos de seguridad.
- **Detección de tecnologías y CMS**: realiza fingerprinting de tecnologías, frameworks y gestores de contenido como WordPress, Joomla o Drupal, adaptando las pruebas de seguridad a cada stack detectado.
- **Escaneo de vulnerabilidades web**: emplea pruebas dinámicas (DAST) para identificar fallos como XSS, inyecciones SQL, exposición de archivos sensibles y configuraciones inseguras.
- **IA para análisis y priorización**: recientemente ha incorporado una herramienta basada en inteligencia artificial, *Alfred*, que ayuda a priorizar vulnerabilidades y

generar pruebas automatizadas.

- **Gestión de activos y generación de informes**: permite agrupar objetivos, gestionar su historial de escaneos y generar informes detallados con recomendaciones técnicas. Estos informes son exportables y compatibles con herramientas como Jira, Slack o GitHub.

Detectify ofrece una experiencia potente y pulida en el ámbito web, especialmente adecuada para equipos de desarrollo que integran la seguridad dentro del ciclo de vida del software (DevSecOps). No obstante, presenta ciertas limitaciones cuando se compara con herramientas orientadas a auditorías ofensivas más amplias. No dispone de ejecución mediante línea de comandos, ni permite escanear servicios que no sean web, como FTP o SSH.

Otro aspecto relevante es que Detectify no ofrece una capa gratuita, lo que lo posiciona claramente como una solución orientada a clientes corporativos con necesidades específicas y presupuesto disponible.

3.3. Comparativa de las soluciones analizadas

La Tabla 3.1 resume las capacidades clave de cada herramienta comparada, destacando tanto las funcionalidades comunes como las características diferenciales que aporta la solución desarrollada.

Característica	**Propuesta**	**ProjectDiscovery Cloud**	**Intruder.io**	**Detectify**
Escaneo de puertos y servicios	✓	✓	✓	✓
Enumeración de subdominios	✓	✓	✓	✓
Reconocimiento DNS	✓	✗	✗	✓
Escaneo específico por CMS	✓	✗	✗	✓
Escaneo de vulnerabilidades web	✓	✓	✓	✓
Reconocimiento específico de servicios	✓	✗	✗	✗
OSINT sobre direcciones de correo	✓	✗	✗	✗
Gestión de proyectos/objetivos	✓	✓	✓	✓
Generación de reportes versionados	✓	✗	✓	✓
IA integrada para asistencia y análisis	✓	✗	✗	✓
Interfaz web	✓	✓	✓	✓
Ejecución por CLI	✓	✓	✗	✗
Servicio gratuito	✓	✓	✗	✗

Tabla 3.1: Comparativa entre la herramienta desarrollada y soluciones similares.

Tras revisar las principales plataformas orientadas al reconocimiento automatizado en auditorías de seguridad, se observa que, si bien ofrecen soluciones potentes en distintos aspectos, presentan limitaciones significativas en cuanto a **personalización**, cobertura de **vectores no web**, o interacción con los resultados obtenidos. Estas carencias evidencian la necesidad de desarrollar herramientas más flexibles y adaptadas a un **análisis técnico más profundo**, como la que se propone en este trabajo.

Capítulo 4

Metodología

Contenidos

4.1. Escaneo de puertos y servicios 19

4.2. Enumeración de dominio 19

4.2.1. Reconocimiento DNS 19

4.2.2. OSINT de direcciones de correo electrónico 20

4.2.3. Enumeración de subdominios 20

4.3. Reconocimiento web 20

4.3.1. Escaneo de vulnerabilidades web 21

4.3.2. Detección de CMS 21

4.3.3. Captura de pantalla del sitio web 21

4.3.4. Enumeración de directorios y archivos 21

4.3.5. Reconocimiento de WordPress 21

4.3.6. Reconocimiento de Joomla 22

4.4. Enumeración del servicio FTP 22

4.5. Reconocimiento del servicio SSH 22

4.6. Generación de reportes 23

4.7. Funcionalidades adicionales 23

La herramienta implementada sigue un flujo de trabajo definido que automatiza de forma secuencial las tareas más relevantes en la fase de reconocimiento de una auditoría de seguridad. A continuación, se describen detalladamente cada una de las fases.

4.1. Escaneo de puertos y servicios

La primera fase consiste en la ejecución de un escaneo con `Nmap`, una herramienta ampliamente utilizada en entornos profesionales. Nmap permite identificar los puertos abiertos en el objetivo, los servicios que están corriendo sobre esos puertos y la versión específica de dichos servicios. Esta información resulta crítica para detectar superficies expuestas, planificar el resto del análisis y orientar futuras fases como la enumeración de vulnerabilidades o fuerza bruta de credenciales.

4.2. Enumeración de dominio

En caso de que el objetivo introducido sea un dominio (en lugar de una dirección IP), se activan tres módulos adicionales que permiten obtener información detallada sobre el mismo.

4.2.1. Reconocimiento DNS

Este módulo se encarga de realizar un reconocimiento pasivo del dominio, recopilando información pública y registros DNS. Se utilizan varias herramientas para llevar a cabo esta tarea:

- `dnsdumpster`: Se encarga de consultar y visualizar registros DNS del dominio, como `MX` (servidores de correo), `NS` (servidores de nombres) y `TXT` (configuraciones SPF, DKIM, etc).
- `mxtoolbox`: Se utiliza para consultar el registro `DMARC`, que proporciona mecanismos de protección ante ataques de suplantación de identidad vía correo electrónico.

- `API Ninja (WHOIS)`: Ejecuta consultas WHOIS para obtener información relacionada con la propiedad del dominio, fechas de creación y expiración, y otros datos relevantes.

4.2.2. OSINT de direcciones de correo electrónico

Tras el análisis DNS, se ejecuta un módulo de OSINT para obtener direcciones de correo electrónico asociadas al dominio, y verificar si estas han sido filtradas en alguna brecha de seguridad:

- `IntelligenceX`: Busca direcciones de correo filtradas asociadas al dominio en bases de datos públicas.
- `LeakCheck`: Comprueba si las direcciones encontradas han sido expuestas, en qué brechas concretas, y qué información fue filtrada. Esta herramienta fue elegida tras descartar alternativas como "Have I Been Pwned.º "DeHashed", que requerían suscripción o tenían limitaciones excesivas.

4.2.3. Enumeración de subdominios

Para ampliar la superficie de ataque, se ejecuta `Subfinder`, una herramienta que utiliza múltiples fuentes para obtener subdominios asociados al dominio objetivo. Posteriormente, se lanza `Httpx` para verificar cuáles de ellos están activos, comprobando su código de respuesta HTTP.

4.3. Reconocimiento web

Si se detecta que el puerto 80 está abierto, se lanzan una serie de modulos para realizar un reconocimiento exhaustivo del servicio web.

4.3.1. Escaneo de vulnerabilidades web

Se procede a escanear el objetivo con `Nuclei`, una herramienta moderna, flexible y en constante actualización. Permite identificar vulnerabilidades comunes y debilidades en aplicaciones web. Si el usuario activa el modo de *escaneo exhaustivo*, Nuclei se ejecutará también sobre todos los subdominios encontrados anteriormente.

4.3.2. Detección de CMS

Se utiliza `WhatWeb` para identificar si el sitio web analizado utiliza un gestor de contenidos (CMS) como WordPress o Joomla. Esta detección permite habilitar fases específicas posteriores, optimizadas para cada plataforma. Además, en caso de que WhatWeb no pueda identificar CMS, se revisa si alguno de los directorios enumerados empieza por `wp-` para determinar si se trata de un sitio WordPress.

4.3.3. Captura de pantalla del sitio web

Para documentar visualmente el estado del objetivo, se emplea la librería `pyppeteer`, que interactúa con el navegador "headless"de Chrome para tomar una captura del sitio web. Esta imagen se incluye en el informe final.

4.3.4. Enumeración de directorios y archivos

En esta fase se utiliza `Feroxbuster`, una herramienta moderna con alto rendimiento, recursividad automática y gran capacidad de gestión de respuestas HTTP. Permite enumerar rutas y archivos ocultos que puedan resultar de interés para el auditor. Si se activa el modo de escaneo exhaustivo, la herramienta realiza una recursividad de nivel 2, enumerando directorios dentro de otros.

4.3.5. Reconocimiento de WordPress

Si el CMS detectado es WordPress, se lanza `WPScan` para enumerar:

- Usuarios del sitio, que se almacenan en una wordlist para fases posteriores.
- Plugins instalados, que se cruzan con bases de datos públicas para buscar CVEs. Si existe un exploit público en GitHub, se clona automáticamente.

En caso de disponer de usuarios enumerados, se lanza un ataque de fuerza bruta mediante `WPScan`, apuntando al recurso `xmlrpc.php`, que permite realizar múltiples intentos de autenticación sin restricciones. Si no se encontraron usuarios, se utiliza una wordlist por defecto con credenciales comunes.

4.3.6. Reconocimiento de Joomla

Si se detecta Joomla como CMS, se ejecuta `Joomscan`, que analiza vulnerabilidades conocidas, archivos de configuración expuestos, copias de seguridad accesibles, y posibles fallos asociados a versiones antiguas del sistema.

4.4. Enumeración del servicio FTP

Si el puerto 21 (FTP) está abierto, se utiliza la librería `ftplib` para interactuar con el servicio. Se comprueba:

- Si permite login anónimo.
- Si existen credenciales válidas (mediante fuerza bruta).
- Si se obtienen permisos de lectura/escritura.
- Se descarga el contenido del servidor y se analiza con `Searchsploit` por si existen vulnerabilidades relacionadas con la versión del servicio.

4.5. Reconocimiento del servicio SSH

Si el puerto 22 está abierto, se lanza un ataque de fuerza bruta con `Hydra`. Inicialmente se consideró la librería `paramiko`, pero fue descartada por no estar diseñada para este

propósito. Se utilizan las mismas wordlists generadas anteriormente si existen usuarios. Además, se analiza la versión del servicio con `Searchsploit` para comprobar posibles vulnerabilidades conocidas.

4.6. Generación de reportes

Una vez finalizado el análisis, la herramienta genera un informe en formato PDF con toda la información recopilada, organizada de forma clara y estructurada. Si el escaneo se ha realizado dentro de un proyecto, el informe se versiona automáticamente, permitiendo mantener un historial completo de auditorías sobre el mismo objetivo.

4.7. Funcionalidades adicionales

- **Asistente de IA**: El sistema integra un modelo generativo (Gemini) que permite al usuario consultar recomendaciones, próximos pasos, análisis de resultados o dudas específicas basadas en el escaneo realizado.
- **Generación de siguientes pasos con IA**: A partir de los resultados obtenidos, el modelo generativo sugiere los próximos pasos a seguir, facilitando la planificación de la auditoría.
- **Sugerencias de soluciones con IA**: El modelo generativo ofrece recomendaciones sobre posibles soluciones a las vulnerabilidades detectadas.
- **Modo de escaneo exhaustivo**: Amplía la profundidad del análisis activando opciones avanzadas en varias fases. Proporciona más información, aunque incrementa el tiempo total del escaneo.
- **Configuración de proxy**: El usuario puede configurar manualmente un proxy desde la interfaz gráfica, útil para evadir bloqueos y especialmente integrado con herramientas como `WPScan`.

- **Sistema de gestión de proyectos**: Desde la interfaz, el usuario puede crear y gestionar proyectos, permitiendo mantener informes versionados, comparar resultados y documentar la evolución del objetivo.

- **Programación de escaneos**: La herramienta permite programar escaneos automáticos a horas específicas, facilitando la planificación y ejecución de auditorías.

Extra: si se quiere lanzar desde consola, basta con ejecutar el archivo `main.py` (python3 main.py ¡target¿[-p] [-ex]). Se le pueden especificar los siguientes parámetros:

- `-p`: Asocia el escaneo a un proyecto existente, permitiendo mantener un historial de auditorías sobre el mismo objetivo.

- `-ex`: Activa el modo de escaneo exhaustivo.

Capítulo 5

Implementación y desarrollo

Lorem ipsum dolor sit amet, consectetuer adipiscing elit. Ut purus elit, vestibulum ut, placerat ac, adipiscing vitae, felis. Curabitur dictum gravida mauris. Nam arcu libero, nonummy eget, consectetuer id, vulputate a, magna.

Capítulo 6

Resultados

Lorem ipsum dolor sit amet, consectetuer adipiscing elit. Ut purus elit, vestibulum ut, placerat ac, adipiscing vitae, felis. Curabitur dictum gravida mauris. Nam arcu libero, nonummy eget, consectetuer id, vulputate a, magna.

Ambling web principal (https://ambling.es/) – Escaneo normal:

Ambling web principal (https://ambling.es/) – Escaneo exahustivo:

Ambling clientes (https://clientes.ambling.es/) – Escaneo normal:

Ambling clientes (https://clientes.ambling.es/) – Escaneo exahustivo:

Ambling caucces (https://caucces.ambling.es/) – Escaneo normal:

Ambling caucces (https://caucces.ambling.es/) – Escaneo exahustivo:

Capítulo 7

Conclusiones y trabajos futuros

Lorem ipsum dolor sit amet, consectetuer adipiscing elit. Ut purus elit, vestibulum ut, placerat ac, adipiscing vitae, felis. Curabitur dictum gravida mauris. Nam arcu libero, nonummy eget, consectetuer id, vulputate a, magna.

Anexos

Anexo A

Ejemplo de anexo

Contenidos

A.1. Sección de anexo 29

Si no se desea incluir anexos, sólo hay que borrar este capítulo.

Lorem ipsum dolor sit amet, consectetuer adipiscing elit. Ut purus elit, vestibulum ut, placerat ac, adipiscing vitae, felis. Curabitur dictum gravida mauris. Nam arcu libero, nonummy eget, consectetuer id, vulputate a, magna.

A.1. Sección de anexo

Lorem ipsum dolor sit amet, consectetuer adipiscing elit. Ut purus elit, vestibulum ut, placerat ac, adipiscing vitae, felis. Curabitur dictum gravida mauris. Nam arcu libero, nonummy eget, consectetuer id, vulputate a, magna.

Bibliografía

[1] MITRE Attack. Reconnaissance, 2020. Táctica de reconocimiento en el marco ATTaCK de MITRE. URL: https://attack.mitre.org/tactics/TA0043/.

[2] James P. Anderson. Computer security technology planning study, volume 1. Technical report, U.S. Air Force Electronic Systems Division, 1972. Informe pionero sobre planificación y análisis de seguridad informática, volumen 1. URL: https://csrc.nist.gov/files/pubs/conference/1998/10/08/proceedings-of-the-21st-nissc-1998/final/docs/early-cs-papers/ande72a.pdf.

[3] James P. Anderson. Computer security technology planning study, volume 2. Technical report, U.S. Air Force Electronic Systems Division, 1972. Informe pionero sobre planificación y análisis de seguridad informática, volumen 2. URL: https://csrc.nist.rip/publications/history/ande72.pdf.

[4] Dan Farmer and Wietse Venema. Satan: Security administrator tool for analyzing networks, 1995. Herramienta pionera de escaneo de vulnerabilidades en redes UNIX. URL: http://www.porcupine.org/satan.

[5] ISECOM. Osstmm – open source security testing methodology manual, 2020. Metodología de auditoría de seguridad. URL: https://www.isecom.org/OSSTMM.3.pdf.

[6] OWASP Foundation. *OWASP Testing Guide v4*. Open Web Application Security Project, 2014. Guía metodológica para pruebas de seguridad. URL: https://owas

p.org/www-project-web-security-testing-guide/assets/archive/OWASP_Testing_Guide_v4.pdf.

[7] ProjectDiscovery. Projectdiscovery cloud platform, 2024. Plataforma de escaneo automático basada en herramientas open source. URL: https://cloud.projectdiscovery.io/.

[8] Intruder Systems Ltd. Intruder.io - automated vulnerability scanner, 2024. Servicio de escaneo de vulnerabilidades orientado a empresas. URL: https://intruder.io/.

[9] Detectify AB. Detectify - web vulnerability scanner powered by ethical hackers, 2024. Plataforma de escaneo web basada en inteligencia colectiva. URL: https://detectify.com/.

[10] INCIBE. ¿qué es una vulnerabilidad zero day?, 2020. Publicación de INCIBE sobre vulnerabilidades de día cero. URL: https://www.incibe.es/ciudadania/blog/que-es-una-vulnerabilidad-zero-day.